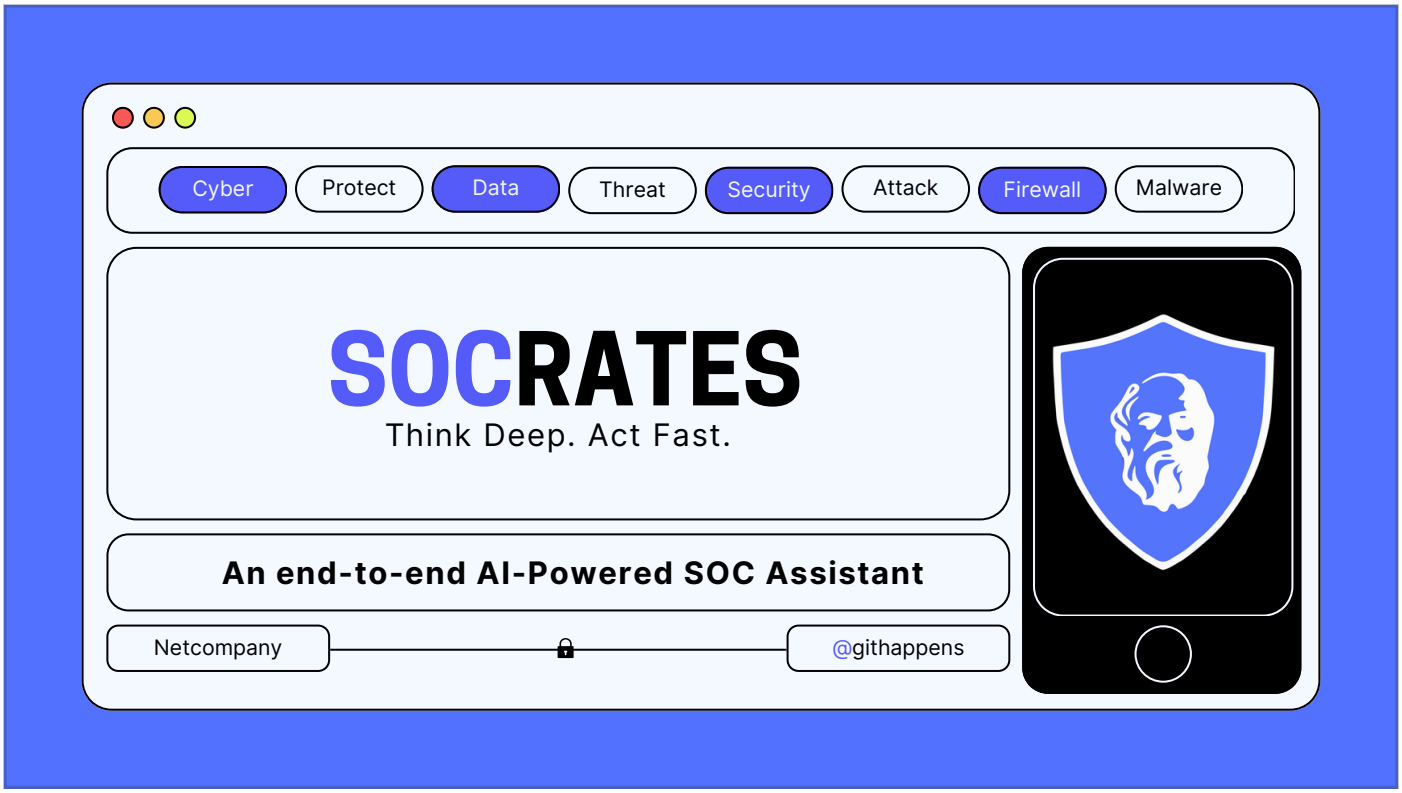



Καλησπέρα σε όλους, είμαι ο Βασίλης και μαζί με τον Σάββα είμαστε η ομάδα git happens.

Μαζί, δημιουργήσαμε το SOCrates: ένα σύστημα που αυτοματοποιεί την καθημερινότητα ενός SOC expert, διατηρώντας τον παράλληλα στο επίκεντρο της λήψης αποφάσεων.

Στόχος μας είναι η βέλτιστη αξιολόγηση των ειδοποιήσεων ασφαλείας και η αμεσότερη δυνατή ανταπόκριση σε κάθε απειλή.

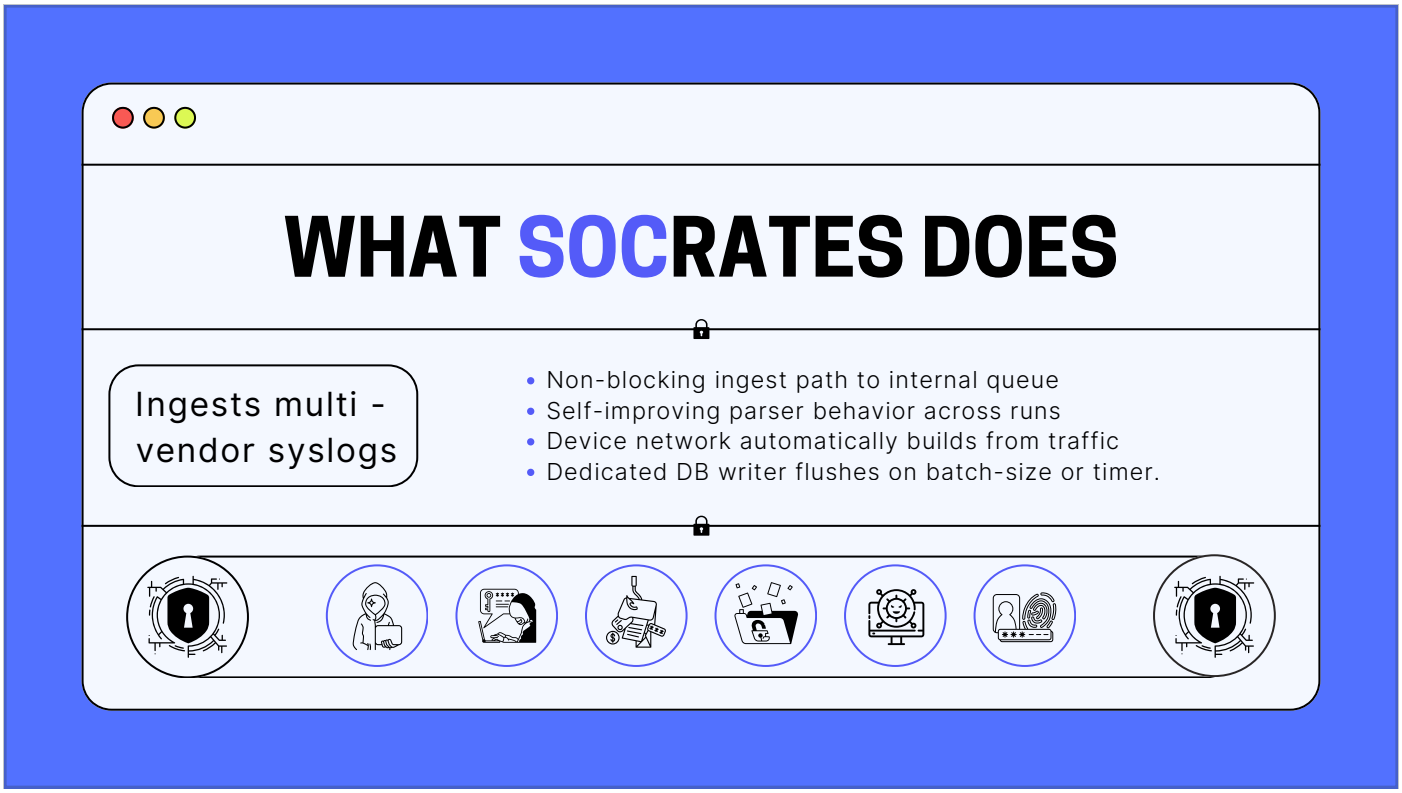
# THE CHALLENGE

- Security teams are overwhelmed by log volume
- Alert fatigue and delayed response
- Hard to bridge monitoring to real remediation

Σήμερα, οι συσκευές ασφαλείας παράγουν έναν τεράστιο όγκο δεδομένων.

Οι αναλυτές καλούνται να ψάξουν χειροκίνητα μέσα σε ακατέργαστα logs για να βρουν την πραγματική απειλή, και μετά να μεταφράσουν αυτό το εύρημα σε άμεση δράση. Το αποτέλεσμα; Χάνεται πολύτιμος χρόνος κατά τη διάρκεια μιας επίθεσης.

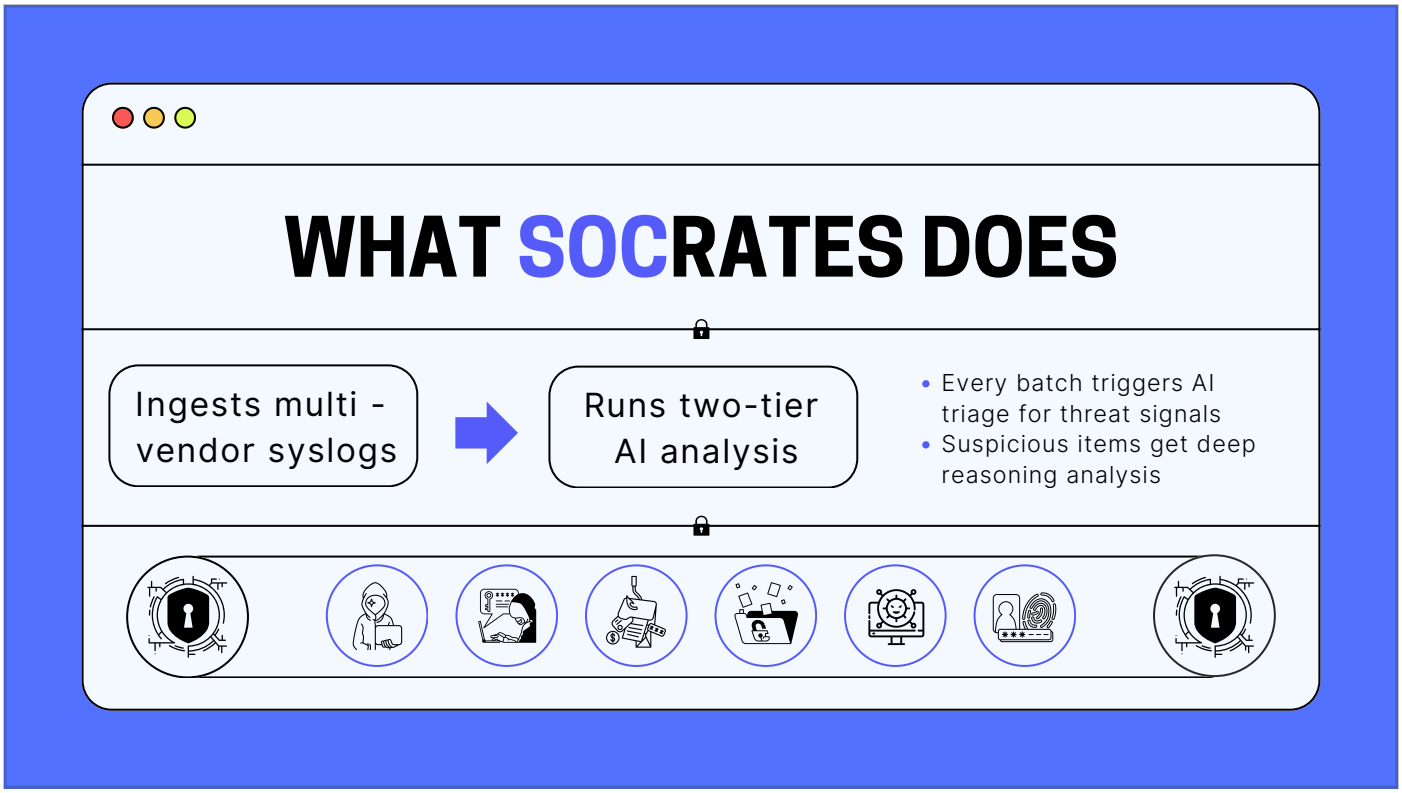
Το SOCrates δημιουργήθηκε για να γεφυρώσει αυτό το χάσμα.




Οπότε, πώς ακριβώς λειτουργεί; Το backend λαμβάνει UDP logs από πραγματικές ή προσομοιωμένες συσκευές, μέσω ενός non-blocking ingest path. Με αυτόν τον τρόπο εξασφαλίζουμε ότι κάθε πακέτο που φτάνει στο σύστημά μας, μπαίνει στην εσωτερική ουρά για επεξεργασία.

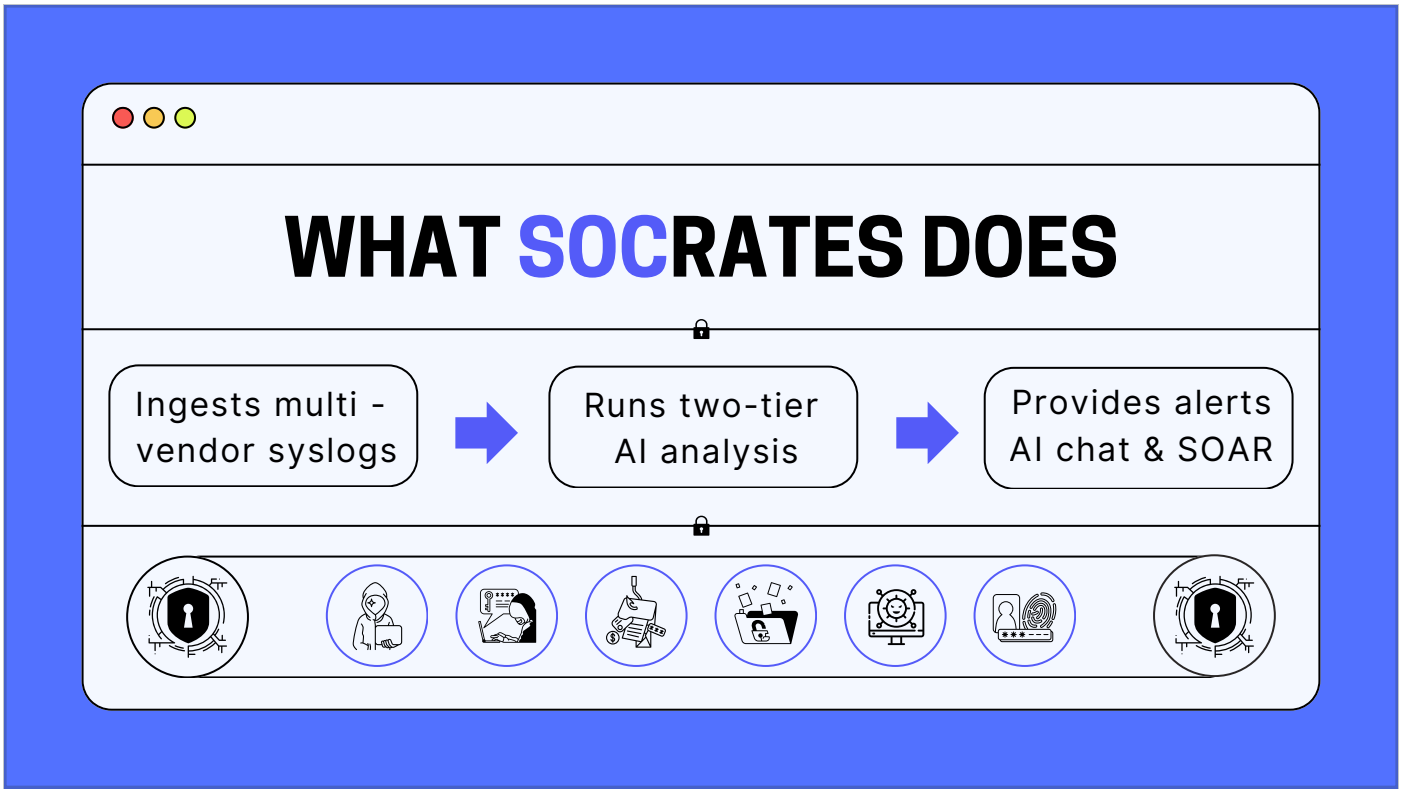
Στη συνέχεια, τα δεδομένα περνούν από τον custom parser που αναπτύξαμε. Εκεί, φιλτράρονται ώστε να κρατήσουμε μόνο την ουσιαστική πληροφορία, εξοικονομώντας έτσι πολύτιμα tokens για τη μετέπειτα ανάλυση. Αυτό γίνεται είτε βάσει γνωστών προτύπων, είτε δυναμικά: δηλαδή αν λάβουμε ένα log από μία πρωτοεμφανιζόμενη συσκευή, το LLM δημιουργεί αυτόματα ένα νέο regex, το οποίο αποθηκεύεται και επαναχρησιμοποιείται.

Ταυτόχρονα, οι συσκευές του δικτύου καταγράφονται αυτόματα στην SQLite βάση μας και παραστούνται σχηματικά ,για γραφική περιήγηση στο frontend. Από την άλλη, τα logs αποθηκεύονται μαζικά, είτε ανά 100 εγγραφές είτε κάθε 2 λεπτά. Η SQLite βάση λειτουργεί αποδοτικά για το demo μας –ειδικά αφού κάνουμε εκτεταμένη χρήση indexes– ωστόσο, σε ένα deployment μεγαλύτερης κλίμακας, θα επιλέγαμε κάτι πιο robust.




Με κάθε batch εγγραφών λοιπόν, τα logs αποστέλλονται στο απλούστερο AI μοντέλο για να αξιολογηθούν ως προς την πιθανότητα κινδύνων και ανωμαλιών. Τα ύποπτα στοιχεία, μαζί με τις πρόσφατες ειδοποιήσεις και το γενικότερο context του δικτύου, περνούν στη συνέχεια από μια εις βάθος ανάλυση (deep reasoning). Αυτή η μεθοδολογία μάς επιτρέπει να έχουμε μια ευρεία, οικονομική σε tokens σάρωση, αλλά και εστιασμένη συλλογιστική που παράγει πλούσια ανάλυση και στοχευμένα mitigation steps.

Για να τεστάρουμε αυτή τη ροή, χρειαστήκαμε ρεαλιστικά δεδομένα. Γι' αυτό, φτιάξαμε έναν δικό μας συνθετικό log generator που προσομοιώνει κίνηση σε firewall βάσει πραγματικών datasets επιθέσεων από τη βιβλιογραφία. Μέσα από αυτό το stress-test εντοπίσαμε και λύσαμε πρακτικά ζητήματα, όπως το alert fatigue, εφαρμόζοντας μηχανισμούς που αποτρέπουν τον καταιγισμό του χρήστη με επαναλαμβανόμενες ειδοποιήσεις. Κάπως έτσι, περνάμε στο πώς βιώνει ο χρήστης αυτή την εμπειρία..




Τι προσφέρουμε τελικά στον χρήστη της εφαρμογής μας;

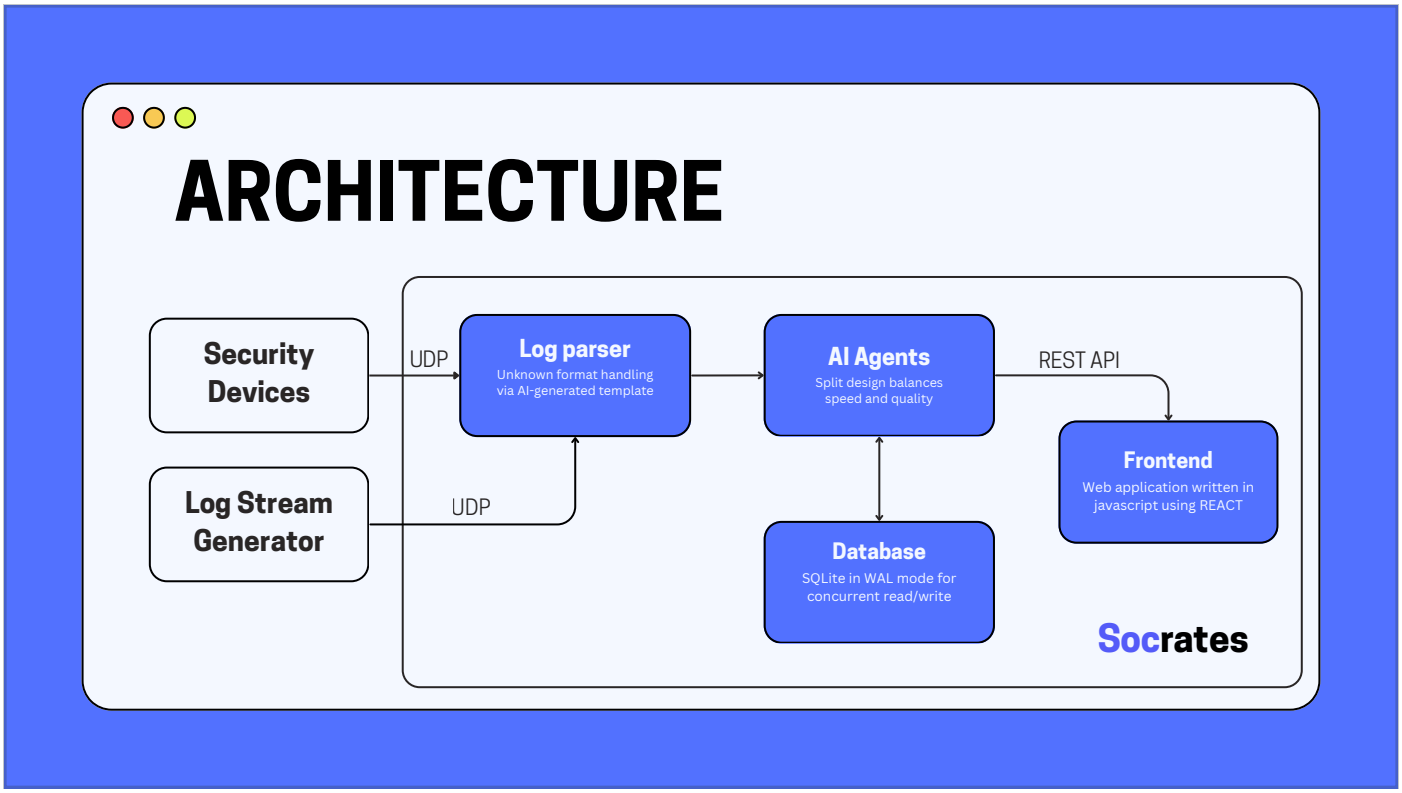
Πρώτον,ξεκάθαρες ειδοποιήσεις για τις απειλές, ταξινομημένες με βάση τη σοβαρότητα και τις επηρεαζόμενες συσκευές.

Δεύτερον, στοχευμένες ενέργειες αντιμετώπισης που εκτελούνται κυριολεκτικά με το πάτημα ενός κουμπιού.

Φυσικά, προσφέρουμε και τη δυνατότητα προαιρετικής, αυτόματης απόκρισης με ενέργειες αποκλεισμού μέσω API playbooks.

Το πιο δυνατό μας σημείο όμως, είναι η δυνατότητα συνομιλίας με την Τεχνητή Νοημοσύνη για την εκάστοτε κατάσταση του δικτύου. Δεν πρόκειται για ένα απλό Q&A bot, έχει την ικανότητα ανάληψης δράσης. Ο χρήστης συνομιλεί σε φυσική γλώσσα, και αν του πεις, για παράδειγμα, "μπλόκαρε αυτή την IP", θα καταλάβει την πρόθεση, θα σου ζητήσει follow-up διευκρινίσεις αν χρειαστεί, και θα εκτελέσει την ενέργεια στο firewall.

Όλα αυτά, πλαισιώνονται από αναλυτικά στατιστικά, το audit trail και το πλήρες ιστορικό των ειδοποιήσεων.




Κάνοντας, λοιπόν, ένα zoom out στην αρχιτεκτονική του project, παρατηρούμε την εξής ροή:

Τα raw logs ρέουν ασταμάτητα στο σύστημα και επεξεργάζονται από τους AI agents, ενώ το Frontend αναλαμβάνει να αντλήσει όλα τα live δεδομένα δυναμικά, κάνοντας polling στα κατάλληλα REST API.

Ήρθε η ώρα, όμως, να τα δούμε όλα αυτά και στην πράξη…

Το περιβάλλον του χρήστη έχει σχεδιαστεί για πραγματικές ροές εργασίας (workflows) ενός SOC, και όχι απλώς για να δείχνει όμορφα γραφήματα. Μπορούμε να διερευνήσουμε μια ειδοποίηση, να τη συσχετίσουμε άμεσα με τα logs που την προκάλεσαν, και να εκτελέσουμε μια ενέργεια αποκλεισμού — όλα μέσα από το ίδιο περιβάλλον.

Το SOCrates αποδεικνύεται ως ένα ολοκληρωμένο σύστημα, κλείνοντας πλήρως τον κύκλο ανίχνευσης και απόκρισης.

Ευχαριστούμε